

DocChat AI

ARCHITECTURE REVIEW PACKAGE

# Security & Architecture Review

For enterprise customers and SOC2 auditors

CONFIDENTIAL — For authorized enterprise review only

DocChat AI | Version 1.0 | May 2026

### 1. System Boundary Definition

DocChat AI operates as a stateless document-processing service with strictly ephemeral compute boundaries.

#### Trust Boundary Layers

- Layer 1 — Client (browser / enterprise SSO)
- Layer 2 — DocChat AI session compute layer (stateless runtime)
- Layer 3 — External inference provider (NVIDIA NIM)

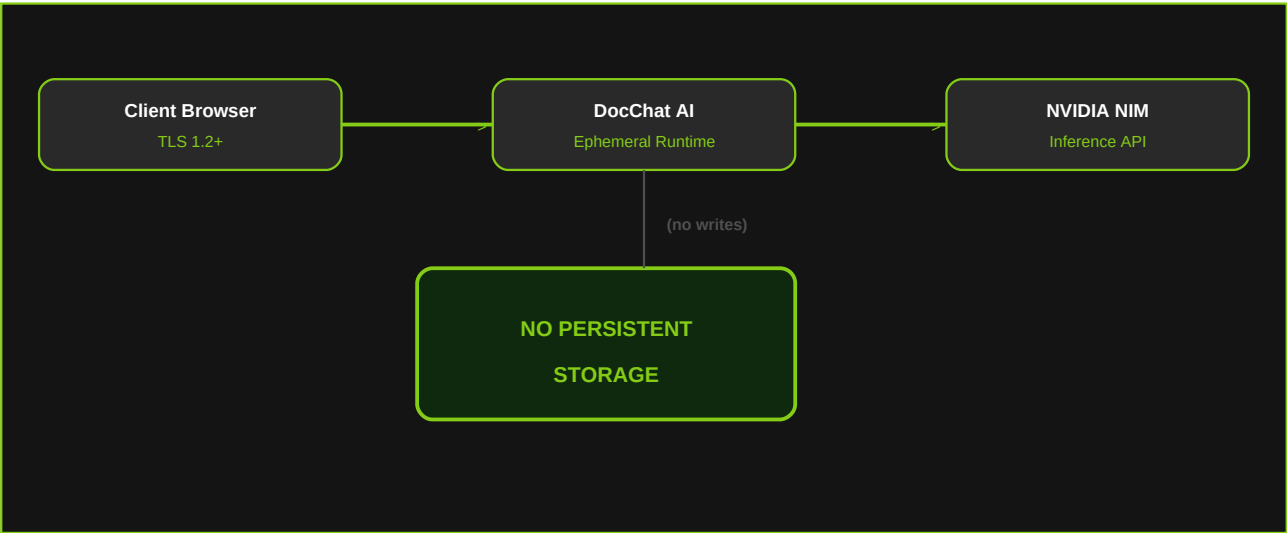
No persistence layer exists within the system boundary.

### 2. Data Flow (Precise)

| Step           | Detail                                                      |
|----------------|-------------------------------------------------------------|
| 1. Upload      | User uploads document via TLS 1.2+ encrypted connection     |
| 2. Memory load | Document loaded into ephemeral RAM only — no disk write     |
| 3. Extraction  | Text extracted and chunked in-session memory                |
| 4. Inference   | Minimal required text sent to NVIDIA NIM inference endpoint |
| 5. Response    | Response returned and rendered to user                      |
| 6. Termination | Session terminates !' memory cleared !' no data remain      |

Invariant: No document or derived content is written to disk, database, object storage, or logs at any step.

### 3. Architecture Diagram



### 4. Key Design Properties

| Component       | Implementation                                           |
|-----------------|----------------------------------------------------------|
| Session storage | In-memory only, per user session — never written to disk |

|                           |                                                                           |
|---------------------------|---------------------------------------------------------------------------|
| Document retention        | 0 — deleted immediately after session ends                                |
| Encryption at rest        | Not applicable (no data stored)                                           |
| Encryption in transit     | TLS 1.2+ (ECDHE, AES-256-GCM, Perfect Forward Secrecy)                    |
| API logging               | No document content — only metadata (timestamp, token count, error codes) |
| Third-party subprocessors | NVIDIA NIM API (text inference only — no training, no storage)            |

5. Security Properties (Explicit Claims)

| Property          | Mechanism                                                      |
|-------------------|----------------------------------------------------------------|
| Zero retention    | No storage interfaces implemented — code inspection verifiable |
| Data isolation    | Per-session memory scope — runtime design                      |
| Transit security  | TLS 1.2+ (ECDHE) — standard external verification              |
| Forward secrecy   | Ephemeral key exchange via TLS handshake                       |
| No insider access | No stored data exists — logical architectural constraint       |

6. Logging Policy

Permitted Log Fields

- Timestamps
- Request size (bytes)
- Token counts
- Error codes

Explicitly Excluded from Logs

- Document content
- Extracted text
- Prompts or model inputs
- Model responses

7. SOC2 Controls Mapping

| Control Category          | DocChat AI Implementation                                            |
|---------------------------|----------------------------------------------------------------------|
| CC6.1 — Logical access    | Session-bound; no long-lived credentials; no stored customer data    |
| CC6.7 — Data retention    | Zero retention — data destroyed immediately post-session             |
| CC7.1 — Monitoring        | Session lifecycle logging (metadata only); anomaly detection         |
| CC1 — Control environment | Security-first architecture; zero-retention by design; RBAC + MFA    |
| CC3 — Risk assessment     | Primary risks identified; TLS + contractual subprocessor constraints |
| CC5 — Control activities  | No persistence eliminates data-at-rest risk class entirely           |
| CC8 — Change management   | Version-controlled; code review required; automated scanning         |

|                        |                                                                                      |
|------------------------|--------------------------------------------------------------------------------------|
| CC9 — Risk mitigation  | Architectural mitigation > procedural; zero-retention eliminates breach blast radius |
| A1.2 — Availability    | Stateless serverless runtime; no storage dependency; reduced failure modes           |
| C1.1 — Confidentiality | TLS + no persistence of PHI/PII at any layer                                         |

8. Threat Model

Mitigated Threats

| Threat                      | Mitigation                                       |
|-----------------------------|--------------------------------------------------|
| In-transit interception     | TLS 1.2+ with Perfect Forward Secrecy            |
| Prompt leakage              | No logging of content at any layer               |
| Cross-session data bleed    | Per-session memory isolation — no shared state   |
| Vendor misuse (NVIDIA)      | Contractual controls; ephemeral request handling |
| Insider access to documents | Impossible — no stored data exists               |

Non-Risks by Design

- Data breach of stored documents — none exist
- Backup exposure — no backups contain customer data
- Database compromise — no database used for customer content

9. Subprocessor Model

| Subprocessor  | NVIDIA NIM API                                              |
|---------------|-------------------------------------------------------------|
| Role          | Real-time document inference                                |
| Data exposure | Minimal text fragments only — no full document transmission |
| Persistence   | No retention (governed by provider contractual terms)       |
| Training      | No customer data used for model training                    |
| Location      | AWS us-east-1 (per NVIDIA infrastructure)                   |

10. Requesting Full Documentation

Enterprise customers may request the following under NDA:

- Full SOC2-aligned architecture diagram
- Incident response plan and summary
- Penetration test summary (annual third-party)
- Full SOC2 control evidence package

Contact: support.docchatai@proton.me